

ACTIVE DIRECTORY BRUTE FORCE DETECTION & INVESTIGATION REPORT

Document Title:	PROJECT 1: Enterprise Authentication Anomaly & Brute Force Investigation
Prepared By:	SOC Detection Engineering Team
Target Assessment:	Windows 10 Workstation ("The-Analyst") & Active Directory Ecosystem
Date of Event:	May 28, 2026
Classification:	CONFIDENTIAL // INTERNAL ONLY

1. Executive Summary

This technical report outlines the end-to-end simulation, telemetry evaluation, and detection engineering pipeline for a high-velocity brute force attack scenario targeted at enterprise authentication components. In this project phase, an offensive adversary simulation platform (Kali Linux) was leveraged to orchestrate a brute force verification run against an open authentication daemon (OpenSSH subsystem) hosted on a standard domain-joined workstation asset (The-Analyst, 192.168.10.10).

The deliberate security incident was successfully identified, recorded, and correlated across a modern defensive architecture. Telemetry validation was confirmed natively via Windows Security Audit events (Event ID 4625) and advanced host infrastructure monitoring logs (Sysmon Event ID 3). These logs were seamlessly aggregated and centralized inside a Splunk SIEM architecture. Finally, production-ready Search Processing Language (SPL) correlation logic was implemented to effectively trap the malicious activity while completely mitigating alert fatigue from baseline organic user mistakes.

2. Environment Architecture & Tooling

The assessment environment functions as a realistic corporate Security Operations Center (SOC) lab infrastructure, incorporating the following segments:

- **Attacker Node:** Kali Linux (Operating from local interface, simulated external malicious router footprint).
- **Target Workstation Asset:** Windows 10 Pro Architecture (Host Profile Name: The-Analyst / IP Endpoint: 192.168.10.10).
- **SIEM Core Engine:** Splunk Enterprise (Centralized log ingestion, analytical parsing, and correlation processing).
- **Host Monitoring Agents:** Microsoft Security Auditing Subsystem & System Monitor (Sysmon v15.x).
- **Perimeter Enforcement (Planned Lab Bounds):** Suricata IDS & pfSense Modular Edge Firewall.

3. Attack Simulation (Offensive Action)

To model realistic adversarial behavior corresponding to systemic password spray and baseline brute force mechanics, the utility **THC-Hydra** was deployed from the attacking node. The target scope was constrained to the network-facing OpenSSH listener on the target machine, simulating an attacker attempting to establish unauthorized remote CLI access using credential lists.

Offensive Execution Command:

```
hydra -t 10 -V -f -l The-Analyst -P passwordlist.txt ssh://192.168.10.10
```

Adversarial Execution Diagnostics:

- **Concurrency Factor (-t 10):** Instructed Hydra to allocate 10 concurrent threads to saturate the validation queue.
- **Verbosity (-v):** Streamed validation pairs in real-time, highlighting a tight, fast cluster of authentication requests.
- **Simulation Footprint:** Exactly 11 validation attempts were sequentially pushed to the target in an automated blast window, concluding at exactly 16:30:26 with 0 successful validations.

4. Host Telemetry Verification & Forensics

Following the execution of the attack, local host forensic analysis was conducted on the target workstation to confirm telemetry integrity before writing correlation rules inside the SIEM.

4.1 Windows Security Audit Log (Event ID 4625)

The local Windows Security Log successfully trapped all authentication failures passed down from the OpenSSH application space. The operating system translated the failures into native **Event ID 4625 (An account failed to log on)** events.

Critical Log Field	Observed Telemetry Content	Analytical Significance
EventCode	4625	Explicitly denotes a failed authentication event.
Target Account Name	The-Analyst	Identifies the precise account name being targeted.
Logon Type	3 (Network Logon)	Confirms remote interactive validation over an open network socket connection.
Source Network Address	192.168.10.x (Attacker IP)	Points directly back to the originating threat actor node.
Process Name	C:\Windows\System32\OpenSSH\sshd.exe	Attributes the authentication handling process directly to the OpenSSH binary.

4.2 Sysmon Operational Log (Event ID 3)

Concurrently, Microsoft System Monitor (Sysmon) logged complementary high-fidelity network-to-process artifacts via **Event ID 3 (Network connection detected)**.

Sysmon Connection Blueprint:

Sysmon recorded an immediate connection surge bound to **DestinationPort: 22 (SSH)** originating from the attacking IP. The connection handling context was directly associated with the process file path: `C:\Program Files\UEMS_CentralServer\jre\bin\java.exe` and standard `sshd.exe` handlers running under the `NT AUTHORITY\SYSTEM` security architecture. This provides critical correlation data link layers for the SOC.

5. SIEM Ingestion & Detection Engineering

Centralized validation was achieved by indexing the host telemetry streams into Splunk Enterprise. To prevent false alerts arising from baseline corporate user typos, an enterprise-grade threshold correlation model was written in Splunk Search Processing Language (SPL).

Production-Grade SPL Detection Query:

```
index=* host="The-Analyst" EventCode=4625
| bucket _time span=5m
| stats count, values(user) as targeted_users, values(ProcessName) as process by _time, host
| where count > 5
| rename count as "Failed Attempts", host as "Target System"
```

Analytical Breakdown of the Engineering Logic:

- 1. Time Bucketing (| bucket _time span=5m):** Normalizes continuous raw log feeds into distinct 5-minute processing windows. This groups brute-force and password spray waves together while isolating unrelated random events.
- 2. Statistical Consolidation (| stats count... by _time, host):** Aggregates the volume counts dynamically while saving the specific targeted usernames as a multi-value array field (`targeted_users`).
- 3. Threshold Constraint (| where count > 5):** Acts as a filter to suppress normal corporate noise. The rule will only fire if an endpoint encounters more than 5 failed validation events within a tight 5-minute interval.

SIEM Correlated Alerts Output:

During detection testing, the logic successfully caught the Hydra sequence, collapsing multiple individual log entries down into a single actionable alert record:

_time Window	Target System	Failed Attempts	Targeted Users List	Process Component Context
2026-05-28 16:25:00	The-Analyst	8	The-Analyst	C: \Windows\System32\OpenSSH\sshd.exe

6. MITRE ATT&CK Mapping

The observed malicious behavior aligns directly with the globally recognized MITRE ATT&CK tactical framework:

- **Tactical Objective:** Credential Access
- **Technique ID:** **T1110 - Brute Force**
- **Sub-Technique Context:** Password Guessing and Multi-Account Spraying behavior designed to bypass default monitoring bounds.
- **Secondary Mapping:** **T1078 - Valid Accounts** (Pre-exploitation reconnaissance phase).

7. Hardening & Remediation Recommendations

To protect the endpoint and wider enterprise infrastructure from automated authentication attacks, the following defensive configuration policies must be implemented immediately:

1. **Enforce SSH Public-Key Authentication:** Deactivate standard password validation within the Windows OpenSSH operational parameters. Access the file path %programdata%\ssh\sshd_config and apply:

```
PasswordAuthentication no  
PubkeyAuthentication yes
```

2. **Implement Account Lockout Threshold Policies:** Deploy a strict Group Policy Object (GPO) across the enterprise domain layer to enforce accounts to lock out temporarily for 15 minutes after 5 continuous validation failures.
3. **Perimeter Layer Restrictive Control:** Apply host firewall and perimeter network protection profiles (via pfSense / local Access Control Lists) ensuring that remote management ports such as SSH (22) and RDP (3389) are strictly blocked from external segments, routing administrative traffic exclusively through encrypted corporate Jump Boxes.
4. **Multi-Factor Authentication (MFA):** Mandate multi-factor verification on all external or network-facing management infrastructure endpoints to neutralize compromised passwords.

8. Lessons Learned & Next Actions

This project successfully proved that relying on vanilla un-correlated log streaming leads to severe alert fatigue. By utilizing precise statistical filters within Splunk, real adversarial actions are easily separated from baseline human error.

Next Development Cycle: With the Windows 10 OpenSSH framework fully documented and defended, the lab infrastructure will pivot towards simulating a massive multi-account SMB and RDP password spray run targeting the Active Directory Windows Server 2019 Domain Controller asset to review enterprise domain replication and cross-endpoint logging behavior.